

MongoDB — Base de datos NoSQL orientada a documentos

Servicio

MongoDB

Puerto por defecto

27017/TCP

Descripción

MongoDB es un sistema de base de datos NoSQL orientado a documentos que almacena datos en formato BSON (Binary JSON). Desarrollado por MongoDB Inc., es ampliamente utilizado en aplicaciones web modernas por su flexibilidad de esquema, escalabilidad horizontal y soporte nativo a JSON. Las instancias MongoDB pueden ejecutarse como proceso único o en arquitecturas de replica sets y sharded clusters. Históricamente, las configuraciones por defecto de MongoDB (antes de la versión 3.6) no requerían autenticación, lo que resultó en millones de registros expuestos públicamente.

Riesgos de seguridad

- **Bases de datos expuestas sin autenticación:** Versiones antiguas de MongoDB escuchaban en `0.0.0.0:27017` sin requerir autenticación por defecto. Millones de registros fueron robados o borrados en ataques masivos (2017: campaña "Ransack MongoDB").
- **Acceso sin autenticación:** Sin `--auth` habilitado, cualquier cliente que alcance el puerto puede leer, modificar o eliminar todas las bases de datos.
- **Permisos excesivos en usuarios:** Usuarios con rol `root` o `dbAdminAnyDatabase` usados por aplicaciones representan un riesgo si la cuenta es comprometida.
- **Exposición a Internet:** MongoDB accesible desde Internet es indexado por motores como Shodan y Censys, siendo objetivo constante de bots automatizados.
- **Inyección NoSQL (NoSQL Injection):** Aplicaciones que no validan la entrada pueden ser vulnerables a inyecciones mediante operadores MongoDB (`$where`, `$gt`, `$regex`), análogo a SQL Injection.
- **Transmisión sin cifrado:** Sin TLS, los datos entre la aplicación y MongoDB viajan en texto plano.
- **Backups expuestos:** Dumps de MongoDB almacenados en buckets S3 públicos o sin cifrar representan una fuente frecuente de filtraciones de datos.
- **Replica set sin autenticación interna:** Nodos de un replica set sin `keyFile` o `x.509` permiten a cualquier host unirse al cluster.

Escenarios de ataque

1. **Ransom MongoDB (2017):** Bots automatizados escanean Internet buscando MongoDB sin autenticación. Al encontrar una instancia, eliminan todas las bases de datos y dejan una nota de rescate exigiendo Bitcoin para "restaurar" los datos (que en realidad ya no existen).
2. **NoSQL Injection en login:** Una aplicación Node.js construye la consulta `{user : req.body.user, password: req.body.password}`. El atacante envía `{"user": {"$gt": ""}, "password": {"$gt": ""}}`, que coincide con el primer usuario en la base de datos, saltando la autenticación.
3. **Exfiltración directa desde Shodan:** Un atacante busca `port:27017 MongoDB` en Shodan, encuentra instancias sin autenticación y ejecuta `mongodump` para extraer terabytes de datos de clientes.
4. **Compromiso por replica set inseguro:** En un cluster mal configurado, el atacante añade un nodo malicioso al replica set aprovechando la ausencia de `keyFile` de autenticación interna, obteniendo una réplica de todos los datos.
5. **Bucket S3 con backup MongoDB expuesto:** El equipo de DevOps almacena backups nocturnos de MongoDB en un bucket S3 sin configurar `Block Public Access`. El atacante encuentra el bucket con Google Dorks y descarga los dumps.

Mitigaciones recomendadas

- **Habilitar autenticación obligatoriamente** (`--auth` o `security.authorization: enabled` en `mongod.conf`).
- Configurar MongoDB para escuchar solo en `localhost` o IPs de red interna (`net.bindIp: 127.0.0.1`).
- **Nunca exponer el puerto 27017 a Internet;** usar firewall para restringir el acceso.
- Crear usuarios con **roles específicos y mínimos privilegios** para cada aplicación (`readWrite` en la DB específica, no `root`).
- Habilitar **TLS para todas las conexiones** (`net.tls.mode: requireTLS`).
- Configurar **keyFile o autenticación x.509** entre nodos de replica set y shards.
- Validar y sanitizar toda entrada de usuario para prevenir NoSQL Injection; usar el driver oficial sin construir queries con concatenación de strings.
- **Cifrar backups** y almacenarlos en ubicaciones de acceso restringido; auditar regularmente los permisos de los buckets de almacenamiento.
- Habilitar **auditoría de MongoDB** (disponible en MongoDB Enterprise) para registrar operaciones de autenticación y modificación de datos.
- Actualizar MongoDB a versiones con soporte activo y aplicar parches de seguridad.

Nivel de exposición

Alto (*Crítico si se ejecuta sin autenticación o con el puerto expuesto a Internet*)

Referencias

- MongoDB Inc. *MongoDB Security Checklist*.
<https://www.mongodb.com/docs/manual/administration/security-checklist/>
- MongoDB Inc. *Enable Access Control (Authentication)*.
<https://www.mongodb.com/docs/manual/tutorial/enable-authentication/>
- OWASP. *Testing for NoSQL Injection*. https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/05.6-Testing_for_NoSQL_Injection
- CISA. *Known Exploited Vulnerabilities Catalog*. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>